

Incident Response Plan

Organization: Rough Cut Manufacturing — operator of WorkTrackPro

Plan Owner: Jacob Rough, Chief Executive Officer — jacobrrough@gmail.com

Version: 1.0 **Effective Date:** June 17, 2026 **Next Review:** June 17, 2027

1. Purpose

This plan defines how Rough Cut Manufacturing prepares for, detects, responds to, and recovers from

information-security incidents affecting the WorkTrackPro application or the data it processes, including customer and financial-account data.

2. Scope

Covers any actual or suspected event that threatens the confidentiality, integrity, or availability of Company or customer data or systems — e.g., unauthorized access, credential or token compromise, data leakage, malware, or provider breaches affecting our data.

3. Roles

- **Incident Lead:** Jacob Rough, CEO — coordinates response, decisions, and external notifications.
- **All staff/contractors:** must report suspected incidents to the Incident Lead immediately via jacobrrough@gmail.com (or direct contact).

4. Severity levels

- **High:** confirmed or likely exposure of sensitive data (PII, financial-account data, or access tokens), or loss of a critical system.
- **Medium:** limited or contained issue with no confirmed sensitive-data exposure.
- **Low:** minor policy or configuration issue with negligible impact.

5. Response phases

1. **Detect & report.** Identify the event from alerts (dependency/security alerts, provider notices, access logs) or staff reports; record time, source, and initial scope.
2. **Triage.** The Incident Lead assigns a severity and opens an incident record.
3. **Contain.** Stop the bleeding: revoke or rotate affected credentials and provider access tokens (Plaid/QuickBooks), disable compromised accounts, restrict access, and isolate affected components.
4. **Eradicate.** Remove the root cause (e.g., patch the vulnerability, remove malicious access, correct the misconfiguration).
5. **Recover.** Restore affected systems/data from trusted backups (Supabase point-in-time recovery), verify integrity, and confirm normal operation.
6. **Notify.** Notify affected individuals, providers, and regulators as required (see §6).

7. **Review.** Within 2 weeks, conduct a post-incident review documenting cause, impact, response, and corrective actions; feed findings into the risk review.

6. Notification

- **Affected individuals and customers:** notified without undue delay when their personal data is reasonably believed to have been compromised, as required by applicable breach-notification law.
- **Plaid:** notified of any security incident affecting Plaid-provided data in accordance with our agreement with Plaid, within the timeframe it requires.
- **Other providers/regulators:** notified as required by contract and law.
- All notifications are coordinated and approved by the Incident Lead.

7. Evidence & documentation

Each incident is documented with timeline, affected data/systems, actions taken, parties notified, and lessons learned. Records are retained for at least 2 years.

8. Preparation & testing

- Keep the subprocessor/contact list current and credentials recoverable.
- Ensure backups and the redeploy path are functional.
- Review this plan at least annually and walk through a tabletop scenario when feasible.